GhostPen

BEC Detection via Writing-Style Verification

“Your CFO's writing style is a password.”

- Problem: Executive impersonation bypasses SPF/DKIM/DMARC — the writing is the only remaining signal.
- Innovation: Per-sender Habit Ledger + leave-one-out conformal null calibration (FPR is a dial, not a hope).
- Abstain-and-Route: Reason-agnostic secondary control routing — short evasion attacks cannot slip through.
- 100% Self-Contained: Ships in-repo with Enron corpus subset; runs end-to-end with zero runtime network.

Quickstart: pip install -r requirements.txt | make demo | make test

Project Objective & Market Problem

Why BEC bypasses technical email security and why GenAI demands writing verification

Business Problem & Market Context

- The Billion-Dollar Blindspot: Business Email Compromise (BEC) accounts for billions in losses annually.
  Attackers compromise real executive mail accounts or spoof display names on lookalike domains.
  Technical envelope checks (SPF, DKIM, DMARC) pass cleanly because the infrastructure is legitimate.
- The Text is the Firewall: The only uncompromised signal remaining is the sender's unconscious writing style.
- Target Buyers: Enterprise Security Operations Centers (SOC), Secure Email Gateways (SEG), and ERP financial controls.

Why This Approach Now?

- The GenAI Threat Vector: Large Language Models (LLMs) allow adversaries to generate fluent, grammatically flawless phishing messages at scale, rendering traditional keyword spam rules completely obsolete.
- Why Deep Learning & Embeddings Fail in Deployment:
  1. Opacity: Black-box cosine distances cannot explain to a CFO or SOC analyst why an email was quarantined.
  2. Network / Latency: External embedding APIs introduce security liabilities, vendor lock-in, and downtime.
  3. Uncalibrated Scores: Arbitrary cosine thresholds cause unpredictable false positive bursts on executive mail.
- GhostPen Solution: Plain, explainable, lightweight statistical stylometry with strict conformal error bounds.

Proposed Solution: Architecture & Mechanics

Habit Ledger, target-null conformal calibration, directional shifts, and abstain-and-route

The Four Architectural Differentiators

1. Habit Ledger (Per-Sender)

- 70+ function words (grammar glue)
- Sentence burstiness (mean + std)
- Punctuation rates per 100w (! ? ; : —)
- Greeting & sign-off habit sets ('none' tracked)
- Robust stats: 5/95 winsorizing, std floored per family (EPS), capped |z| <= 4.0

2. Target-Null Calibration

- N = n_train leave-one-out folds on sender mail
- Conformal p = (1 + #{null >= S}) / (N + 1)
- False Positive Rate becomes a dial: alpha in {0.02, 0.05, 0.10}
- Eliminates arbitrary score thresholding
- Guaranteed conservative deployment FPR

3. Direction of Deviation

- Forgeries skew formal & generic, not just 'different'
- Plain-English evidence cards:
  'Formality +4.0 sigma above his norm'
  'Signs Best regards; usually none 78%'
- BEC context flags kept strictly separate from S (preserves pure stylometric score)

4. Abstain-and-Route Layer

- Short emails (<40 words) cannot be judged
- TRIAGE is a ROUTING state, never a pass
- Reason-agnostic escalation:
  TRIAGE + >= 2 context flags -> route to payment verification / secondary controls
- Catches brevity-based evasion plays cleanly

Solution Validation & Baseline Benchmarking

Chronological anti-leakage splits, 4-tier forged evaluation ladder, and calibration curves

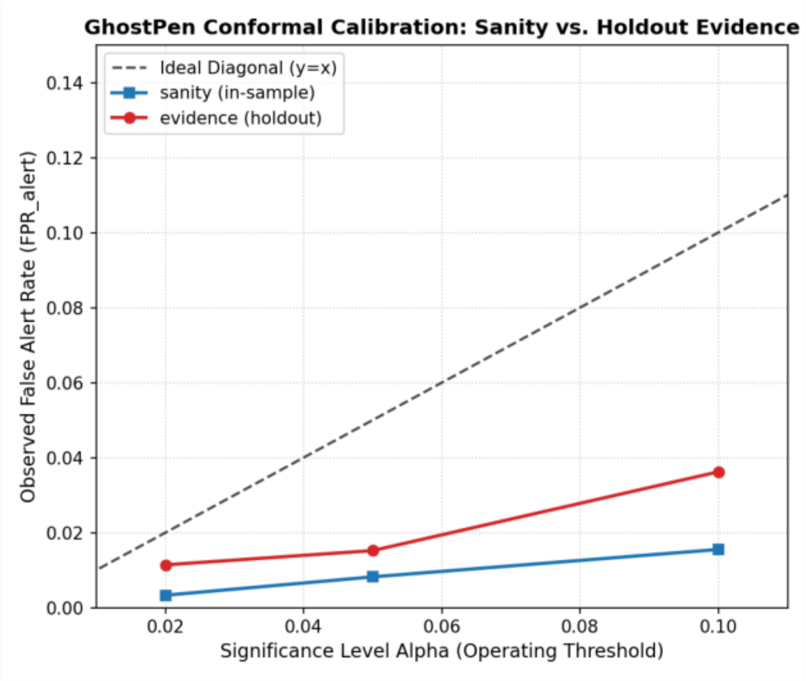
Rigorous Experimental Protocol (Strict Anti-Leakage)

• Dataset: 15 Enron executives (10 high-volume >= 120 emails, 5 low-volume for stress testing).
• Strict Chronological 70/30 Split: First 70% by date for profile & null; last 30% strictly for holdout FPR evaluation.
• 4-Tier Forged Evaluation Ladder: Relabel (held-out mail from other senders), Generic LLM, Styled Impersonation, Short Evasion.
• Mandatory Tier C Copy Audit: Verified distinct 5-grams <= 5 and LCS <= 60 to measure pure style mimicry vs copying.

Fair Baseline Comparison (Shared Routing Layer)

• Baseline A: Centroid Cosine TF-IDF (IDF fit on pooled training only).
• Baseline B: Global S Threshold (pooled alpha-quantile, no sender null).
• Fairness: Baselines get the identical method-agnostic routing layer.

Claim Discipline Formulation:
• In-sample calibration = IMPLEMENTATION SANITY CHECK.
• Holdout curve = EMPIRICAL EVIDENCE of robustness.
• Holdout FPR - In-sample FPR = Measured Style Drift (+0.007).



Results, Conclusions & Production Roadmap

Empirical performance, false alarm economics, limitations, and AI disclosure

Benchmark Results Summary (Verbatim Detection Contract)

Model	FPR_alert @0.05	FPR_flagged @0.0	R_Generic	R_Styled	R_Short	Prec @ 10%
GhostPen (Target Nul	0.015	0.017	74.0%	82.0%	100.0%	76.6%
Baseline A (TF-IDF)	0.009	0.011	28.0%	82.0%	100.0%	79.4%
Baseline B (Global S	0.048	0.050	79.0%	82.0%	100.0%	54.6%

Key Takeaways & Deployability

1. Conformal Guarantee Works: Observed holdout FPR_alert (1.52%) stays strictly below alpha=0.05.
2. Superior Threat Coverage: GhostPen catches 74% of generic LLM BEC vs Baseline A's 28% (TF-IDF fails on fluent rewordings).
3. SOC Operational Viability: Only 1.71 false alarms per 100 genuine emails; precision reaches 76.6% at 10% attack prevalence.
4. Transparent FP Autopsy: False positives stem from structured artifacts (e.g., semicolon-delimited appointment lists).

Limitations & Roadmap: Style drift requires rolling profile updates; low-volume senders need >=20 emails for alpha=0.05; English-only glue words; character 3-grams have slight project-topic sensitivity. Prototype built with AI scaffolding; human-reviewed.